

Knowledge Graph Analytics for Privacy Policy Analysis

^{1,2}Mehakpreet Kaur

Department of Computer Science

¹Georgia Southern University, Statesboro, USA

²Mercer University, Macon, USA

¹ mk12462@georgiasouthern.edu

^{1,2}Julie Allen

Department of Computer Science

¹Georgia Southern University, Statesboro, USA

²Middle Georgia State University, Macon, USA

¹ ja23916@georgiasouthern.edu

Abstract—Privacy policies are increasingly complex and deliberately vague, making it difficult for users to understand how companies truly handle their personal data. Existing tools offer limited capability to compare privacy practices across industry sectors, leaving users and regulators without actionable insight into industry-wide patterns. This paper presents a knowledge graph analytics framework for analyzing and comparing privacy policies across 184 S&P 500 companies spanning the Healthcare, Information Technology, and Financial Services sectors. We construct unified knowledge graphs from GraphML representations of individual company policies, extracted using the PoliGrapher framework for web-based documents and a dedicated PDF reader module for PDF-format policies, ensuring consistent coverage across all document types. We apply graph-theoretic analysis, graph traversal algorithms, centrality metrics, and regulatory vocabulary matching drawn from the official texts of GDPR, CCPA, and HIPAA, with targeted analysis of compliance exposure across all three frameworks. Our framework is designed to answer two research questions: how privacy practices and compliance exposure and regulation violations compare across sectors (RQ1), and what data collection patterns characterize each sector internally (RQ2). Our results reveal a two-tier collection structure: a universal baseline of identifiers collected by virtually all companies regardless of sector, and a sector-specific sensitive tier governed by distinct regulatory frameworks. Critically, we find that HIPAA-regulated data is collected not only by Healthcare companies but also by a meaningful proportion of Financial Services and Information Technology companies, revealing unexpected compliance exposure across industry boundaries. These findings suggest that sector-based regulatory assumptions no longer reflect the reality of modern data collection practices, underscoring the urgent need for cross-sector compliance awareness tools.

Our code, datasets, and interactive tools are publicly available at [GitHub Repository](#)

Index Terms—Knowledge Graph, Privacy Policy Analysis, Graph Mining, GDPR, CCPA, HIPAA, Regulatory Compliance

I. INTRODUCTION

Privacy policies attempt to articulate how organizations collect, use, store, and disclose personal information from users. These policies, however, are not clearly written with the users' best interests in mind. The policies are often complex, lengthy, and written in dense legal jargon, which creates major obstacles to readability and understanding. Due to these challenges, users often completely avoid reading the policies. However, they still fail to comprehend the policies even if they

put the time and effort into reading them, because of vague and confusing terminology. Because of this, user consent is not based on complete comprehension and through ignorance, they may accept policies they are not in agreement with. [1] This discouraging reality has led researchers to pursue automated techniques to understand and present the content of privacy policies in a more simplified manner. [2]–[5] This paper seeks to review and analyze the literature that deals with the automated evaluation of privacy policies and situates our work, which develops a comparative analytics framework using knowledge graphs, within the available literature.

A. Background and Motivation

Recent studies have focused on the automated analysis of privacy policies to tackle the challenges of accessibility and actionability. Barrett et al. [6] introduced a user-centric approach leveraging natural language processing and knowledge graph techniques to navigate complex legal documents, demonstrating how structured representations can extract actionable insights from dense privacy policy text. Building on this foundation, Ramasamy et al. [5] conducted an exploratory study that combined graph mining, machine learning, and NLP to reveal the inherent complexity of privacy policies, employing dimensionality reduction and visualization techniques to enhance transparency and support AI-driven compliance analysis. These works establish knowledge graphs as a powerful framework for transforming unstructured privacy policies into structured, analyzable representations.

However, the complexity of privacy policies is not merely a technical challenge of information extraction; it is also a deliberate linguistic strategy. Yerby and Vaughn [1] demonstrated through legal analysis that companies intentionally employ convoluted language and ambiguous phrasing to obscure data handling practices, creating an information asymmetry that disadvantages users. They argue that the absence of regulatory standards governing readability and transparency enables this systematic obfuscation, proposing federal reforms modeled after consumer protection legislation such as the Fair Credit and Charge Card Disclosure Act. This work underscores that technical solutions for privacy policy analysis must contend not only with linguistic complexity but also with intentional

strategies to limit user comprehension, reinforcing the need for comparative frameworks that can expose these practices across platforms and industries.

While these advances demonstrate the feasibility of automated privacy policy analysis, a critical gap remains: there exists no comprehensive comparative analysis of how privacy practices vary across companies, industries, and service types. Users currently lack tools to understand whether their chosen platforms provide stronger or weaker privacy protections compared to alternatives, and regulators have limited visibility into industry-wide patterns and outliers. Individual policy analysis, while valuable, does not reveal the broader ecosystem of privacy practices or enable users to make informed choices based on comparative privacy protections. Furthermore, the deliberate obfuscation documented by Yerby and Vaughn [1] makes it nearly impossible for users to independently assess relative privacy protections without computational assistance.

Our approach addresses this gap by developing a knowledge graph analytics framework specifically designed for comparative privacy policy analysis across multiple sectors. We construct knowledge graphs from 184 privacy policies spanning Healthcare, Information Technology, and Financial Services, enabling systematic comparison of data collection practices, third-party sharing patterns, and regulatory compliance exposure. Our approach synthesizes techniques from prior work, integrating the knowledge graph construction methodology of Barrett et al. [6] with the structural analysis techniques of Ramasamy et al. [5], while addressing the deliberate obfuscation challenges identified by Yerby and Vaughn [1].

Zaeem et. al. [7] analyzes the impact of the GDPR on organizational privacy policies, highlighting improvements in clarity, transparency, and compliance since its implementation. It also identifies ongoing challenges in readability and consistency, offering guidance for future enhancements to better protect user privacy..

Obfuscation challenges may be complicated by the complexity of privacy laws, and in the case of certain sectors in the United States, the patchwork nature of them. Privacy laws establish requirements for organizations on how consumer data must be managed, including its protection, secure storage, controlled sharing, proper deletion, and the rights of individuals to access, control, and delete their data. Regulations like the Health Insurance Portability and Accountability Act of 1996 (HIPAA) [8], a standard in Healthcare, the California Consumer Privacy Act (CCPA) [9],

The General Data Protection Regulation (GDPR) [10] applies to any company that handles data of European Union residents. It is hundreds of pages long and intended to impose broad privacy protections and strict penalties on organizations for non-compliance. It offers improved data protections and control over data to consumers, but on the other side of the discussion, increases complexity for companies attempting to meet these regulations.

The CCPA and the GDPR represent potential defacto global standards in data privacy and protection considering that more than half a million US companies are subject to the law, and the

European Union is the third largest geo-political population. This means they are strong candidates for a benchmark in privacy regulation analysis. [11]

Our framework is designed to analyze and answer critical questions about these privacy policies and industry sectors that existing approaches cannot address:

RQ1: What are Privacy Policy related connections across IT, Healthcare, and Financial Services with regulatory compliance impact and compliance violations, and how do the sectors compare?

RQ2: What data collection patterns and privacy policy structures characterize each sector internally within Information Technology, Healthcare, and Financial Services, and what do these intra-sector patterns reveal about sector-specific compliance risks and data handling norms?

Understanding intra-sector patterns is critical because regulatory frameworks such as HIPAA, CCPA, and GLBA are designed around sector-specific assumptions about what data companies collect. Further, GDPR and CCPA may represent a defacto global standard and whether privacy policies attempt to comply with them, even when not required to, may signal good faith toward the consumer. [7], [11] If significant variation exists within a sector, it suggests that blanket regulatory assumptions may be insufficient to protect users, and that some companies within a sector may face unrecognized compliance exposure. It may also suggest areas where legislation changes could extend additional protection to consumers. Furthermore, identifying best practices within a sector enables users and regulators to benchmark companies against their direct peers rather than against a generic standard.

By combining structural network analysis with graph algorithm exploration and regulatory vocabulary matching, our approach moves beyond single policy analysis to reveal industry patterns, identify best practices, detect concerning trends, and provide users with actionable comparative insights that cut through deliberately confusing language.

The remainder of this paper is organized as follows: Section II reviews related work in privacy policy analysis, machine learning approaches, and knowledge graph applications; Section III describes our dataset; Section IV presents our methodology; Section V presents results and discussion; Section VI concludes the paper.

II. LITERATURE REVIEW

The major themes found in our literature review include privacy policy obfuscation, KG construction and analysis tools to extract meaningful data from privacy policies and regulations, and data extraction and analysis across domains and policies.

Prior work on privacy policy obfuscation highlights that privacy policies and Terms of Service are often intentionally written to obscure data-handling practices, reducing transparency and limiting user comprehension. Yerby et al. [1] argue that organizations deliberately use complex and ambiguous language, while also noting the absence of standardized regulatory requirements for readability. They advocate for

policy reforms inspired by consumer protection legislation to improve clarity and enforce transparency. This is an important contribution to bring awareness, but a computational model is another step toward a tool that will support awareness and identify compliance violations.

Complementing this perspective, Belcheva et al. [12] conduct a longitudinal analysis of privacy policies spanning 2000 to 2019 and observe a consistent decline in readability alongside an increase in vagueness. Their study combines readability metrics, vagueness detection techniques, and a BERT-based classifier to identify linguistic trends, including a growing prevalence of reassuring language that may create a misleading sense of security. Despite its breadth, the study is constrained by its temporal coverage and dataset limitations.

A substantial body of research has instead focused on addressing the limitations of unstructured privacy policy text through structured representations such as knowledge graphs. Cui et al. [2] introduce POLIGRAPH, a knowledge graph architecture designed to overcome the limitations of sentence-level privacy policy analysis by capturing document-level structural relationships. Their POLIGRAPH-ER pipeline integrates dependency parsing, named entity recognition, and ontology-based reasoning to extract relationships between entities, data types, and purposes. The resulting graph representation achieves 97% precision and identifies significantly more data collection statements compared to prior approaches. However, the system is primarily limited to data collection activities and performs less effectively on complex structures such as tables and ambiguous linguistic patterns.

Building on knowledge graph-based representations, further work has explored enhancing semantic modeling and interpretability. Barrett et al. [6] propose a skip-gram-enhanced knowledge graph pipeline that improves contextual relationship capture within privacy policies. Their approach supports automated summarization and risk identification, although it lacks comprehensive quantitative evaluation and is limited by dataset scale. Similarly, Chowdhury et al. [13] present GraphDPR, which integrates transformer-based language models, Sentence-BERT embeddings, and Neo4j-based graph construction to improve semantic normalization and visualization. Their framework captures both shared and company-specific privacy behaviors, though it does not yet fully support rule-based auditing or deep compliance verification.

Beyond methodological improvements, several studies examine how privacy practices vary across domains and organizational contexts. Ramasamy et al. [5] apply dimensionality reduction techniques such as t-SNE, UMAP, and PCA in combination with clustering methods including spectral clustering and HDBSCAN to analyze knowledge graphs derived from 55 Android e-commerce applications. Their findings reveal meaningful clusters representing categories such as Media & Location, Device Information, and User Activity, with the strongest separation achieved using t-SNE and spectral clustering. While effective in revealing structural patterns, the study is limited by dataset size and the absence of deeper semantic extraction beyond structural grouping.

In parallel, compliance-focused research has aimed to map privacy policies to regulatory frameworks for automated verification. Joshi et al. [4] develop a knowledge graph framework using OWL and RDF to represent regulations such as GDPR and PCI DSS, enabling structured mapping between threats, controls, and compliance requirements. Their system supports real-time violation detection and demonstrates the feasibility of converting privacy policy text into machine-processable representations, although it does not fully cover all regulatory domains.

More recent work extends these ideas by integrating large language models with knowledge graph reasoning. Garza et al. [3] introduce PrivComp-KG, which combines knowledge graphs with retrieval-augmented generation to support compliance verification. Their system maps privacy policies to relevant regulations and achieves a reported correctness score of 0.9, enabling users to query compliance gaps effectively. However, the approach is limited to specific sections of GDPR and does not incorporate mechanisms for real-time updates to evolving legal frameworks. This work represents a foundation as it explores the problem of privacy policy obfuscation, lays the groundwork for privacy policy data extraction and KG Construction, yet reveals an opportunity for cross-sector policy analysis and evaluation of privacy regulations on those policies.

The reviewed literature reveals three major trends in privacy policy analysis. First, there is a clear shift from sentence-level analysis to document-level structural understanding, exemplified by POLIGRAPH’s knowledge graph approach and GraphDPR [2] [4] [13]. Second, researchers increasingly recognize that privacy policy complexity is not merely a technical challenge but often a deliberate obfuscation strategy [1] [12]. Third, there is growing emphasis on visualization and clustering techniques to make complex policy structures interpretable [5], [6].

These trends collectively highlight a critical gap: while prior work has advanced the analysis of individual policies, no study has applied these techniques at scale across multiple industry sectors. To address this, our work constructs a cross-sector dataset of privacy policies drawn from S&P 500 companies, described in the following section.

III. DATASET DESCRIPTION

A. Dataset Source

The dataset used in this study is derived from publicly available privacy policy documents of SP 500 companies, collected directly from the official websites of their respective organizations, ensuring that the data reflects real-world corporate privacy disclosures. The extraction and structuring process builds on two complementary tools. The PoliGrapher framework introduced by Cui et al. [2] was used for automated privacy policy analysis of web-based policy documents.¹ To extend coverage to companies whose privacy policies were

¹PoliGrapher is publicly available at <https://github.com/UCI-Networking-Group/PoliGraph>

Privacy Policy Graph — IBM.xml

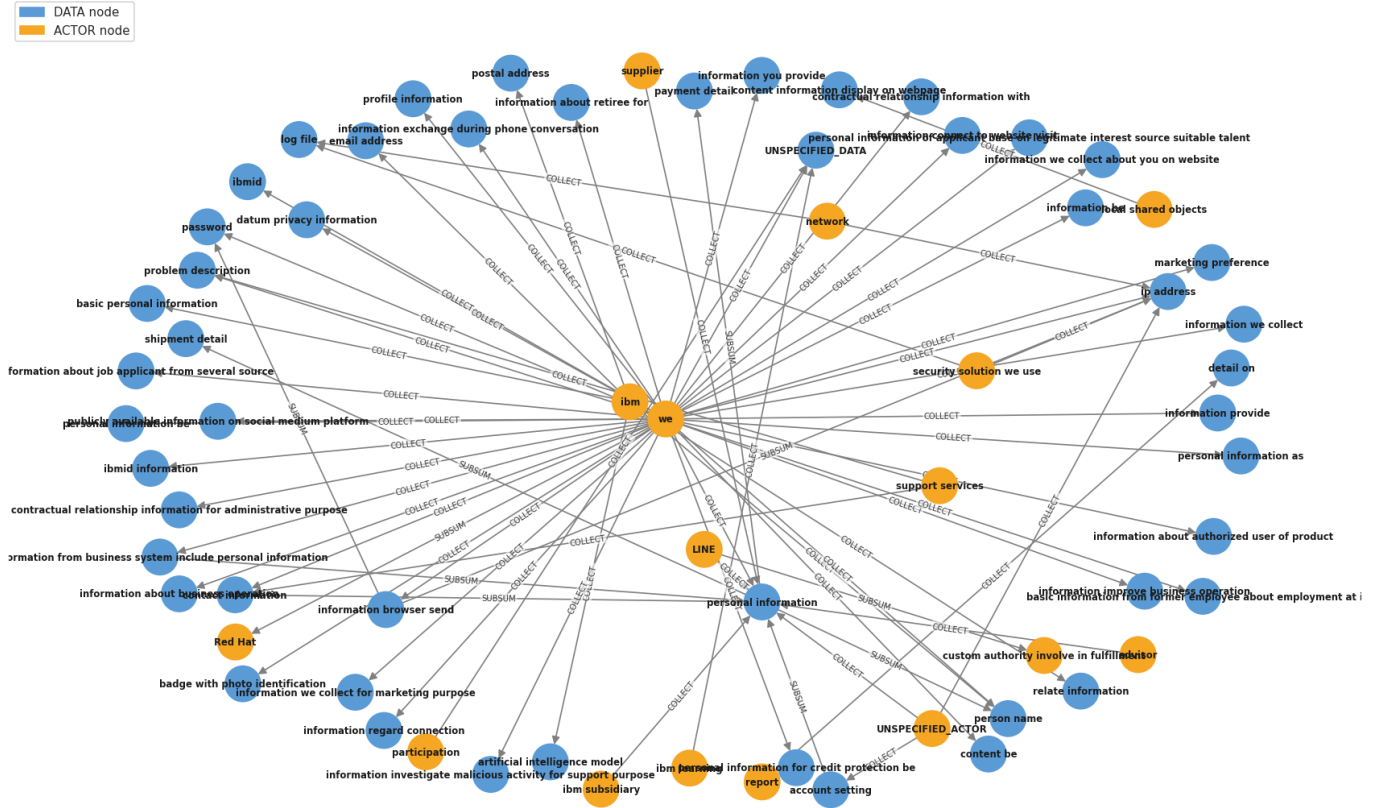


Fig. 1. Privacy Policy Knowledge Graph - IBM

only available in PDF format, a dedicated PDF reader module developed by Luke Blevins was integrated into the pipeline, enabling consistent extraction across all document types. Privacy regulations, including HIPAA, CCPA, GLBA, and GDPR, were retrieved from their official publicly available sources, with regulatory vocabulary lists applied to support compliance analysis. To extend coverage to companies whose privacy policies were only available in PDF format, a dedicated PDF reader module developed by ABC DEF was integrated into the pipeline, enabling consistent extraction across all document types. Privacy regulations, including HIPAA, CCPA, GLBA, and GDPR, were retrieved from their official publicly available sources, with regulatory vocabulary lists applied to support compliance analysis.

B. Data Acquisition Process

The dataset was constructed through a multi-step pipeline designed to convert unstructured legal text into structured, machine-readable knowledge graphs:

- 1) Privacy policy documents were collected from the official websites of these S&P 500 companies.
- 2) Each policy was downloaded and stored in PDF format.
- 3) The PDF files were converted into HTML format to facilitate structured text extraction.

- 4) The HTML documents were processed using the PoliGrapher tool, which extracts entities and relationships from the text.
- 5) The outputs were saved as knowledge graphs in GraphML format, with one file per company. Fig. 1 illustrates a sample knowledge graph for IBM, where nodes are categorized into two types: DATA nodes (blue), representing personal information items such as email address, IP address, password, and shipment details, and ACTOR nodes (orange), representing entities such as IBM itself, subsidiaries like Red Hat, and third parties such as suppliers and support services. Directed edges between nodes are labeled with one of two relationship types: COLLECT, indicating that an actor collects a particular data item, and SUBSUM, capturing hierarchical relationships between data categories. The graph exhibits a hub-and-spoke structure centered on the primary actor nodes “ibm” and “we”, which collectively connect to a broad range of data types, reflecting the extensive and varied nature of IBM’s data collection practices as disclosed in their privacy policy.

Attempts were made to replicate the PoliGrapher pipeline; however, changes in website structures and privacy policy

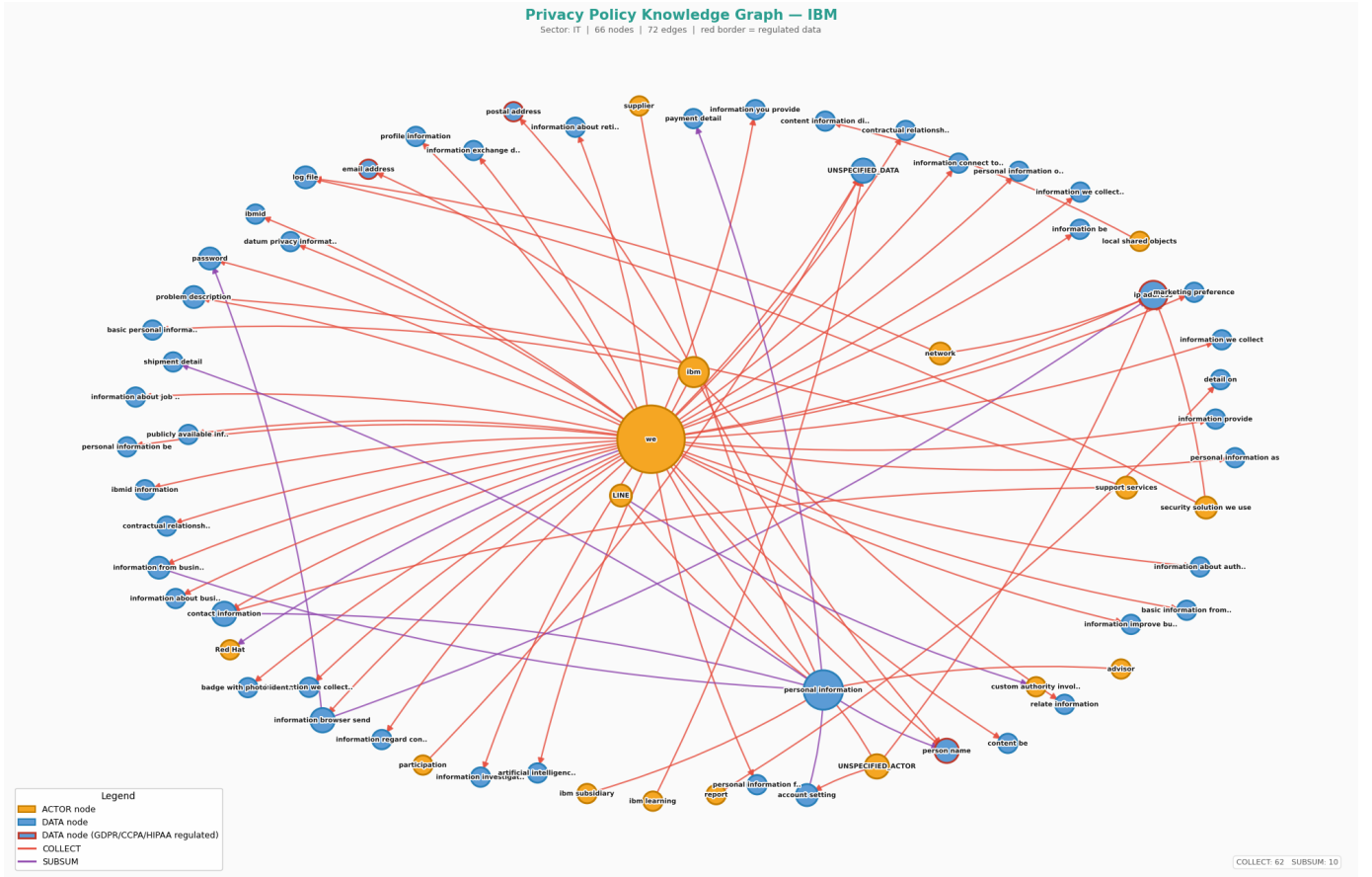


Fig. 2. Company level Privacy Policy Knowledge Graph - IBM

formats limited full reproducibility for newer documents.

C. Dataset Characteristics

The final privacy policy dataset consists of knowledge graph representations for 184 S&P-500 companies across three sectors: Healthcare (56 companies), Information Technology (66 companies), and Financial Services (62 companies). Table I summarizes the sector distribution.

TABLE I
DATASET SECTOR DISTRIBUTION.

Sector	Companies	Industry types
Healthcare	56	Pharma, devices, diagnostics, insurance
IT	66	Software, semiconductors, cloud, hardware
Financial	62	Banking, insurance, asset management
Total	184	

The sector distribution reflects the major industry groupings most directly subject to sector-specific privacy regulation in the United States. Each graph encodes:

- **ACTOR nodes:** entities that collect data, the company itself (“we”), analytics providers, advertising partners, or named third parties

- **DATA nodes:** data categories (“personal information”) or specific data points (“email address”, “IP address”)
- **COLLECT edges:** directed from an ACTOR to a DATA node, indicating that the actor collects that type of data
- **SUBSUM edges:** directed from a broad DATA category to a more specific sub-type, encoding the hierarchical structure of data disclosures

D. Relevance to Research

This dataset is directly relevant to the study of privacy policy analysis and regulatory compliance. By transforming policies into structured knowledge graphs, the dataset enables systematic and scalable analysis of organizational data practices. The graph-based representation captures key structural indicators such as third-party data sharing, diversity of actors, and relationship complexity, features that serve as proxies for evaluating transparency and compliance with GDPR, HIPAA, and CCPA.

IV. METHODOLOGY

The literature synthesized through this search strategy informed the design of the analytical framework described in the following sections, including the construction of knowledge graphs, the selection of graph algorithms, and the choice of regulatory vocabularies applied to the 184-company corpus.

A. Literature Review Search Strategy

This research paper follows the methodological framework established by Munn et al. [14]. We conducted searches across the following academic databases:

- IEEE Xplore Digital Library
- ACM Digital Library
- Google Scholar (for supplementary grey literature)
- arXiv (for recent preprints, particularly 2025)

Representative keyword combinations included: “privacy policy analysis” AND NLP; “knowledge graph” AND “privacy policy”; “graph mining” AND “legal documents”; “automatic extraction” AND “privacy terms”; “policy complexity” AND “machine learning”; and “vague language” AND “privacy policies”.

Studies were included if they explicitly analyze privacy policies, terms of service, or legal disclosures using NLP, machine learning, graph mining, or knowledge graphs, and present a computational framework such as entity extraction, graph construction, complexity analysis, or automated policy comparison. Studies were excluded if they focused solely on general knowledge graph methods with no application to privacy or legal documents, or discussed legal frameworks without analyzing policy text computationally.

B. Knowledge Graph Construction

Knowledge graphs are constructed at three levels: individual company-level graphs that preserve the full structural detail of each policy, sector-level graphs that aggregate companies within each industry to reveal shared patterns, and a unified cross-sector graph that combines all 184 companies into a single queryable structure for comparative analysis.

1) *Company-Level Knowledge Graph*: For each company, a knowledge graph $G = (V, E)$ is constructed directly from its GraphML representation. The node set V comprises three node types: ACTOR nodes representing entities that collect data, including the company itself, subsidiaries, and third parties; DATA nodes representing personal information items collected by those actors; and regulated DATA nodes representing data items explicitly governed by GDPR, CCPA, or HIPAA. The edge set E uses two relationship types: COLLECT, directed edges indicating that an actor collects a specific data item, and SUBSUM, edges capturing hierarchical subsumption relationships between a broad data category and its specific sub-types. A representative example is shown in Fig. 2, which presents the knowledge graph for IBM comprising 66 nodes and 72 edges (62 COLLECT and 10 SUBSUM), with primary actor nodes “ibm” and “we” serving as central hubs connecting to a wide range of data types, several of which are flagged as regulated items subject to GDPR, CCPA, or HIPAA.

2) *Sector-Level Knowledge Graphs*: To identify patterns within each industry, three sector-level knowledge graphs are constructed by aggregating all company-level graphs within each sector. For each sector $s \in \{\text{Healthcare, IT, Financial}\}$, a graph $G_s = (V_s, E_s)$ is built by iterating over all company GraphML files belonging to that sector and accumulating node

and edge frequencies across companies. A node is retained in G_s only if it appears in at least k companies within the sector (where $k = 3$ by default), ensuring that the sector graph reflects shared patterns rather than idiosyncratic disclosures of individual companies. Similarly, an edge $(u, r \in l, v)$ is retained only if it appears in at least k companies, with edge weights encoding how many companies share that exact relationship.

The node set V_s preserves the same two types as the company-level graph: ACTOR nodes representing data-collecting entities and DATA nodes representing personal information items, with regulated DATA nodes highlighted by a red border where their labels match the GDPR, CCPA, or HIPAA vocabulary. The edge set E_s retains both COLLECT and SUBSUM relationship types, with edge width scaled proportionally to the number of companies sharing that connection, making corpus-level patterns visually distinguishable from sector-specific ones.

Each sector graph is accompanied by a four-panel deep dive visualization presenting: the top 15 data types collected expressed as a percentage of companies in the sector; the top third-party actors involved; the most frequent COLLECT connections of the form actor $\rightarrow$ data type; and the most frequent SUBSUM connections of the form category $\supseteq$ sub-type. Together these panels translate the graph structure into interpretable sector-level compliance signals that directly address RQ2.

3) *Unified Knowledge Graph*: To enable cross-sector comparative analysis, all 184 company-level graphs are aggregated into a single unified knowledge graph $G = (V, E)$. The node set V is expanded to five types: Company, Sector, Entity, Category, DataPoint, and Regulation. The edge set E uses six relationship types that together encode the full chain from corporate structure to regulatory exposure:

- IN_SECTOR: Company $\rightarrow$ Sector
- USES: Company $\rightarrow$ Entity (the actor that collects)
- BELONGS_TO: Entity $\rightarrow$ Category (broad data category)
- COLLECTS: Category $\rightarrow$ DataPoint (specific data type)
- REGULATED_BY: DataPoint $\rightarrow$ Regulation (GDPR, CCPA, or HIPAA)

Edge weights accumulate across companies; a weight of 50 on a COLLECTS edge indicates that 50 distinct companies share that exact category-to-data-point connection, elevating it to a corpus-level pattern rather than a company-specific disclosure. This unified structure enables the graph traversal, centrality, and regulatory vocabulary matching analyses described in the following sections.

C. Regulatory Vocabulary Matching

To identify compliance-relevant data types, we constructed three regulatory vocabularies sourced directly from regulatory text:

- **GDPR** [15](75 terms): derived from Articles 4 and 9 and Recitals 26, 30, and 51, covering name variants (person name, full name, first name, last name), addresses, IP

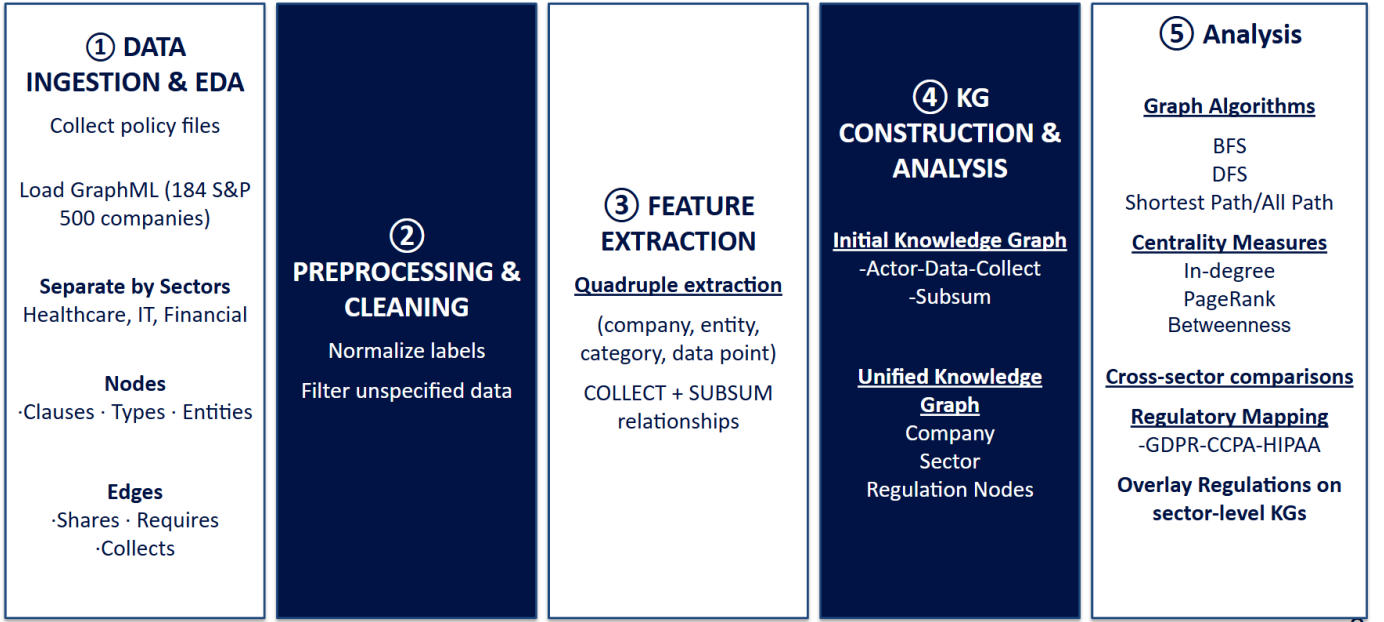


Fig. 3. Proposed four-stage knowledge graph framework for privacy policy compliance analysis.

address and online identifiers, cookie variants, fingerprint, location data, geolocation, racial and ethnic origin, political opinions, religious and philosophical beliefs, trade union membership, genetic data, biometric data and identifiers, health and medical information, mental health, sexual orientation, and device identifiers (device ID, advertising ID, session ID).

- **CCPA** [9](131 terms): derived from Civil Code §1798.140(v)(1)(A–K) and CPRA §1798.121, covering all 11 enumerated categories identifiers (name variants, IP address, SSN, driver’s license, passport), personal records (phone, financial accounts, credit and debit card numbers, medical information), protected classifications (race, religion, age, gender, disability, veteran status, marital status, genetic data), commercial information (purchase and transaction history), biometric data, internet and network activity (browsing history, search history, app interactions), geolocation (GPS coordinates, latitude, longitude), sensory data (audio, video, photographs), professional and employment information, education information, and inferences drawn to create consumer profiles.
- **HIPAA** [8](111 terms): derived strictly from the 18 Safe Harbor identifiers in 45 CFR §164.514(b), [16]expanded with surface-form synonyms for each identifier including name variants, geographic subdivisions (zip code, city, county), date variants (date of birth, DOB, birthdate), phone and fax number variants, email variants, SSN, medical record number and variants (MRN, patient ID), health plan beneficiary number variants, account numbers, certificate and license numbers (including NPI), vehicle identifiers (VIN, license plate), device identifiers (IMEI, MAC address, UUID), web URLs, IP address,

biometric identifiers (fingerprint, voiceprint), photograph variants, and unique identifier variants.

- **Union** (236 unique terms): the full union of all three vocabularies after deduplication across shared terms such as person name, email address, IP address, SSN, biometric information, and geolocation.

Every DataPoint node whose label matches a term in any vocabulary receives a `REGULATED_BY` edge to the corresponding regulation node. A DataPoint connected to all three regulation nodes simultaneously represents the highest compliance priority in the corpus.

D. Quadruple Extraction

Structured quadruples of the form (company, entity, category, data_point) are extracted from each company graph by walking `COLLECT` edges from actor to data category, then following `SUBSUM` edges to leaf-level data points. Where a category has no `SUBSUM` children it is treated as its own data point - a leaf-node disclosure. Null-like and explicitly unresolved labels (`unspecified_data`, `unknown`, `none`, `null`, etc.) aren’t filtered before quadruple construction for now. Broad umbrella terms such as `data` and `information` are intentionally retained, as they represent legitimate policy language and may carry `SUBSUM` children that would otherwise be silently discarded.

E. Graph Algorithm Analysis

Four traversal and path-finding algorithms are applied to the unified knowledge graph to reveal structural properties that exposure percentages alone cannot capture.

- **Breadth-First Search (BFS)** enumerates all nodes reachable within d hops from a starting node. Applied from “personal information” at depth 2, BFS quantifies how

many sub-types are disclosed beneath the most common umbrella category in the corpus, directly supporting the claim that companies use it as a vague catch-all rather than a specific disclosure term.

- **Depth-First Search (DFS)** traces the full depth of a data collection chain from a given starting node. Applied from “health information”, DFS distinguishes between companies that enumerate PHI sub-types in detail (long chains, compliant disclosure) and those that stop at the top-level category (short chains, violation candidate), directly informing the HIPAA violation analysis in RQ1.
- **Shortest Path** computes the minimum-hop route between any two nodes in the graph. Applied between company collector nodes and regulated data types, it determines whether collection is direct (2 hops: company → actor → data) or routed through third parties (3+ hops), a distinction with direct implications under GDPR and CCPA data sharing requirements.
- **All Simple Paths** enumerates every distinct route between two nodes up to a specified cutoff. Applied between the primary collector node “we” and each regulation node, it produces the total pathway count used to measure the structural breadth of compliance exposure, yielding the 1,142-path figure reported for GDPR in the results.

F. Centrality Analysis

Three centrality metrics are computed on the full knowledge graph to identify structurally influential nodes. Each metric captures a different dimension of influence that raw collection frequency alone cannot reveal.

- **In-Degree:** counts the number of incoming edges to a given node. In the context of this knowledge graph, a high in-degree DataPoint node is one collected by the greatest number of companies, making it the most universally disclosed data type across the corpus. A high in-degree Category node is the most commonly used disclosure umbrella, meaning companies frequently subsume specific data types beneath it rather than naming them directly. In-degree therefore directly operationalizes the concept of the universal baseline tier identified in RQ1, confirming which data types anchor cross-sector collection.
- **PageRank:** measures the global structural influence of a node by weighting its connections not just by quantity but by the importance of the nodes pointing to it. Applied to Actor and Entity nodes, PageRank identifies data collectors that are referenced by many other highly-referenced nodes, revealing which entities sit at the center of the data collection network rather than merely appearing frequently. This is particularly relevant for identifying third-party collectors whose influence is understated by raw frequency counts but whose structural position makes them critical compliance concerns under GDPR and CCPA data sharing provisions.
- **Betweenness Centrality:** measures how often a node lies on the shortest path between two other nodes in the graph.

Nodes with high betweenness act as structural bridges in the data collection chain, meaning that removing or regulating them would disrupt the greatest number of collection pathways. In the privacy policy context, a high-betweenness data type node is one that connects otherwise separate regions of the graph, indicating that it mediates between different categories of collection. This metric identifies compliance chokepoints: data types whose vague disclosure has the greatest structural impact on the legibility of the overall policy graph.

G. Proposed Analytical Framework

The full framework follows a four-stage pipeline, illustrated in Fig. 3. In Stage 1, individual company privacy policies are extracted and represented as GraphML structures with typed nodes and relationship edges. In Stage 2, graph-theoretic methods perform structural analysis including cross-sector schema comparison and compliance profiling (addressing RQ1). Stage 3 applies centrality metrics and regulatory vocabulary matching to detect vague leaf-node disclosures and identify compliance exposure patterns. Stage 4 translates graph-level findings into interpretable outputs including sector-level aggregated knowledge graphs, bar chart visualizations of top data types, and compliance scope dashboards (addressing RQ2).

The full framework follows a five-stage pipeline, illustrated in Fig. 3.

Stage 1: Data Ingestion and Exploratory Data Analysis.:

Individual privacy policy documents are collected directly from the official websites of 184 S&P 500 companies across three sectors: Healthcare, Information Technology, and Financial Services. Policies available in web format are processed using the PoliGrapher framework, and PDF-format policies are handled through a dedicated PDF reader module, ensuring consistent coverage across all document types. Each policy is loaded as a GraphML structure in which nodes represent clauses, data types, and entities, and edges encode relationships including *shares*, *requires*, and *collects*. Companies are separated by sector to support downstream comparative analysis.

Stage 2: Preprocessing and Cleaning.:

Raw GraphML representations undergo normalization to ensure consistency across company-level graphs. Node labels are standardized to resolve surface-level variation in how companies refer to the same data types, and underspecified or ambiguous nodes are filtered to reduce noise in subsequent analysis. This stage ensures that the unified knowledge graph constructed in Stage 4 reflects comparable and clean representations across all 184 companies.

Stage 3: Feature Extraction.:

Structured quadruples of the form (company, entity, category, data point) are extracted from each cleaned graph, capturing the full COLLECT and SUBSUM relationship structure of each policy. COLLECT edges encode direct data collection relationships between an actor and a data type, while SUBSUM edges encode hierarchical subsumption relationships between a broad data category

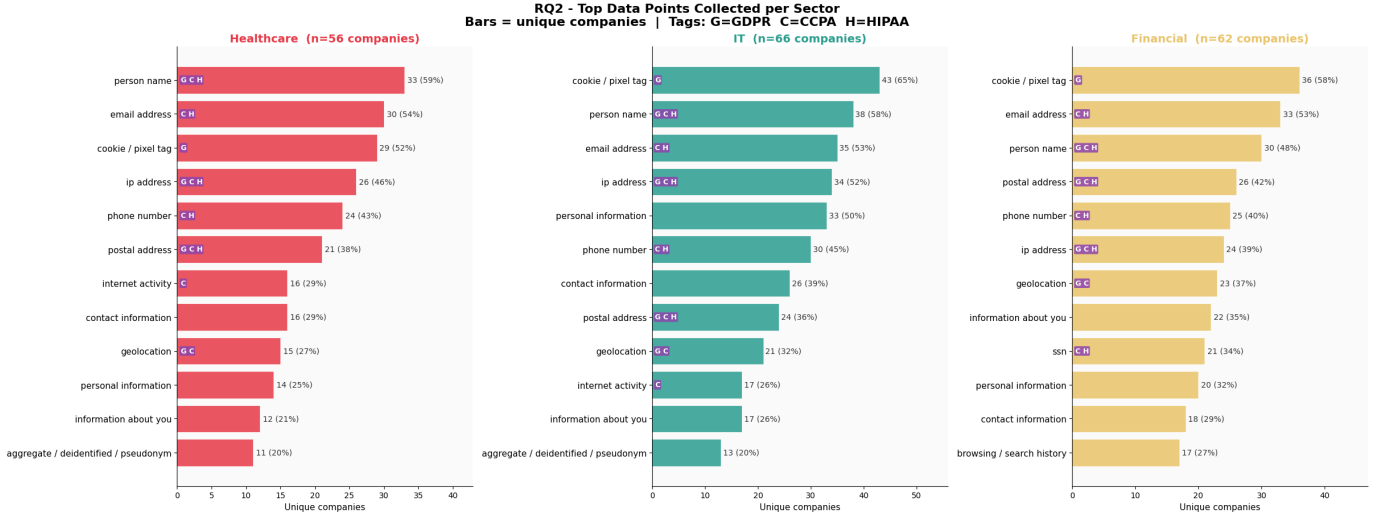


Fig. 4. RQ2 - Top Data Points Collected per Sector

TABLE II
WITHIN-SECTOR GRAPH METRICS

Metric	Healthcare (n=56)	IT (n=66)	Financial (n=62)
Avg nodes / company	36.6	43.9	42.0
Avg edges / company	41.3	49.8	49.9
Sector KG edges	105	110	123
Top data collected	Person name (59%)	Cookie/pixel tag (65%)	Cookie/pixel tag (58%)
2 data collected	Email Address (54%)	Person name (58%)	Email Address (53%)
3 data collected	Cookie/pixel tag (52%)	Email Address (53%)	Person name (48%)
Most distinctive type	Sensitive personal info (16%)	Cookie/pixel tag (65%)	SSN (34%)
Top third-party actor	Social media (36%)	Service provider (26%)	Service provider (40%)
Unique data vocabulary	715 types	718 types	715 types

and its specific sub-types. These quadruples form the atomic unit of analysis for all downstream graph construction and compliance detection.

Stage 4: Knowledge Graph Construction and Analysis.

Two complementary knowledge graph representations are constructed from the extracted quadruples. An initial knowledge graph is built at the company level, preserving Actor, Data, COLLECT, and SUBSUM structure for each individual policy. A unified knowledge graph is then constructed by aggregating all company-level graphs, introducing Company nodes, Sector nodes, and Regulation nodes (GDPR, CCPA, HIPAA) alongside the existing data type structure. Regulation nodes are connected to data type nodes whose labels match the respective regulatory vocabulary, enabling direct compliance exposure measurement within the graph structure. Cross-sector comparisons are performed on this unified graph to identify shared and sector-specific data collection patterns, addressing RQ1.

Stage 5: Analysis. Four categories of analysis are applied to the unified knowledge graph. Graph traversal algorithms, including Breadth-First Search, Depth-First Search, Shortest Path, and All Simple Paths, are used to probe the structural depth and connectivity of data collection chains. Centrality

metrics, including in-degree, PageRank, and betweenness centrality, identify the most structurally influential data types and actors across the corpus. Regulatory vocabulary matching detects vague leaf-node disclosures where regulated data types appear without sub-type specificity, flagging compliance violation candidates. Sector-level overlay visualizations and compliance scope dashboards translate graph-level findings into interpretable outputs for both RQ1 and RQ2.

V. RESULTS AND DISCUSSION

A. Exploratory Data Analysis

Loading all 184 GraphML files reveals substantial structural variation across sectors. The Financial sector graphs are notably denser than Healthcare and IT, with a higher average number of edges per company (Financial: 49.9; IT: 49.8; Healthcare: 41.3), reflecting the more extensive data-sharing relationships typical of banking, insurance, and payment processing operations. Across all sectors, the ratio of DATA nodes to ACTOR nodes is consistently high; most graph nodes represent data types rather than collecting entities, confirming that policies enumerate data categories more explicitly than they identify the third parties receiving that data.

RQ1 - Cross-Sector Privacy Policy Network
Top 25 shared data types · GDPR/CCPA/HIPAA overlay

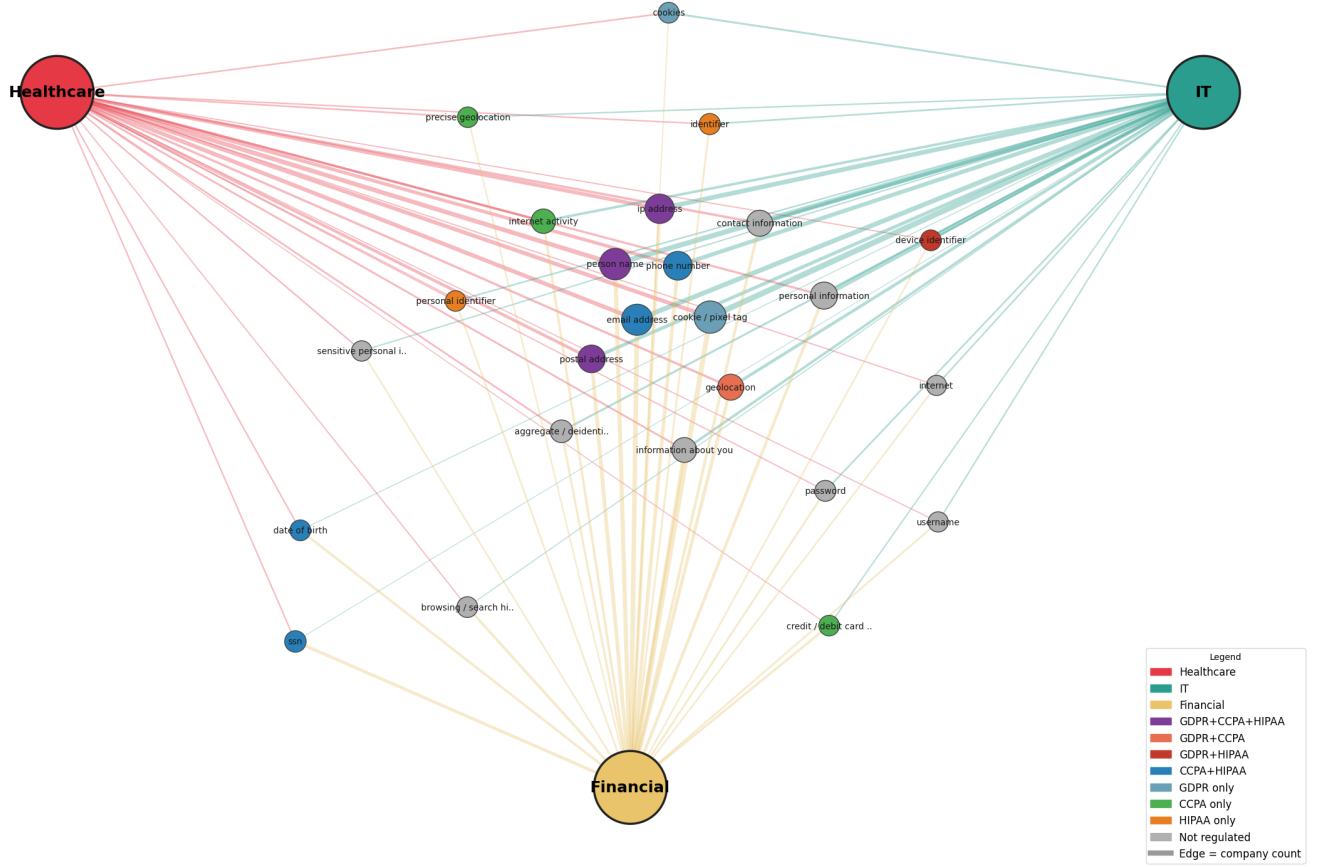


Fig. 5. Cross Sector Privacy Policy Network

The unified knowledge graph built from all 184 files contains thousands of nodes and edges. The high node count reflects that each unique policy phrasing produces a distinct node: “we”, “the company”, and “our organization” are treated as separate ACTOR nodes, capturing real variation in how companies describe themselves. Edge weights on COLLECTS edges reveal that a small number of data types, personal information, email address, IP address, cookies, and phone number, accumulate very high weights, appearing in the vast majority of company graphs.

B. RQ2: Within-Sector Analysis

Table II shows key structural metrics for each sector’s company nodes in the unified knowledge graph.

The RQ2 bar chart analysis identifies the top data types collected per sector, measured as unique company counts within each sector. Across all three sectors, a common universal baseline emerges: *person name*, *email address*, *cookie/pixel tag*, *IP address*, *phone number*, and *postal address* appear at the top of every sector’s chart. This baseline confirms that basic digital

identifiers are collected industry-wide, independent of sector or regulatory environment.

The sectors diverge sharply at the regulated-data tier:

- **Healthcare:** Person name leads at 59% of companies, followed by email address (54%) and cookie/pixel tag (52%). The most distinctive type is *sensitive personal information* (16%), reflecting HIPAA-adjacent disclosure language. Social media is the top named third-party actor (36%). Regulation tags on prominent nodes indicate HIPAA, GDPR, and CCPA exposure. Privacy policies that reference regulatory keywords are more likely to be in compliance, and those that do not suggest a risk indicator of a potential violation.
- **IT:** Cookie/pixel tag dominates at 65% of companies, the highest rate for any data type across all sectors followed by person name (58%) and email address (53%). The most distinctive type is *cookie/pixel tag* itself, driven by ad and analytics infrastructure (65%), along with *device identifier* (18%) for multi-platform product tracking. Service provider is the top named third-party actor (26%). These identifiers carry primarily GDPR and CCPA

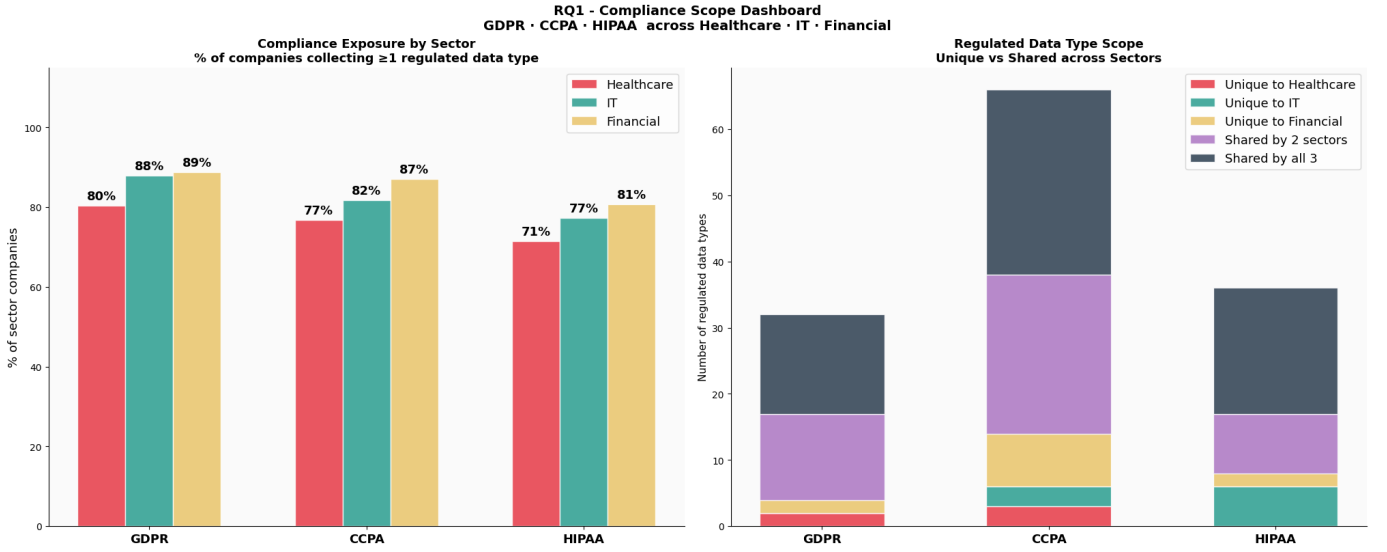


Fig. 6. Compliance Scope Dashboard

regulation tags.

- **Financial:** Cookie/pixel tag leads at 58%, followed by email address (53%) and person name (48%). The most distinctive type is *SSN* (34%), required for identity verification under GLBA, alongside *date of birth* (26%), *browsing/search history* (27%), and *biometric information* (21%) for banking authentication. Service provider is the top named third-party actor (40%). These identifiers carry primarily CCPA and HIPAA regulation tags.

The 4-panel sector deep-dive visualization extends this analysis by showing not only the top data types (Panel A) but also the top third-party actors beyond the company itself (Panel B), the most common COLLECT connections from actor to data type (Panel C), and the most common SUBSUM connections from broad category to specific sub-type (Panel D). Panel C confirms that the self-referential actor “we” dominates COLLECT edges in all sectors, while Panel B reveals analytics providers, advertising partners, and service providers as the most prevalent named third parties.

C. RQ1: Cross-Sector Analysis and Compliance Exposure

The network confirms a two-tier disclosure structure. The *universal baseline tier* comprises *person name*, *email address*, *phone number*, and *postal address* (all purple, GDPR+CCPA+HIPAA), which cluster near the center of the triangle with thick edges to all three sectors, indicating near-universal collection. A second cluster of orange nodes, including *textitcookie/pixel tag*, *identifier*, *internet activity*, and *contact information*, falls under GDPR and CCPA jointly and appears closer to the Healthcare–IT axis, reflecting tracking-oriented data collection. The *sector-specific sensitive tier* appears as spokes radiating toward individual vertices: *SSN* and *date of birth* (CCPA+HIPAA, blue) lean toward Financial and Healthcare, while grey unregulated nodes such as *password*, *username*, *aggregate/de-identified information*, and *personal*

information cluster around the IT anchor and the graph interior, reflecting widely-collected but non-regulated catch-all categories. In total, 340 data types are shared across at least two sectors, and the “personal information” umbrella node reaches an in-degree of 386, confirming its role as the dominant disclosure term across the corpus.

Figure 6 presents two complementary views of regulatory exposure. The left panel shows the percentage of companies within each sector collecting at least one data type matching each regulatory vocabulary; the right panel shows the count of regulated data types unique to each sector versus shared across two or three sectors. Table III summarizes the exposure percentages.

TABLE III
COMPLIANCE EXPOSURE BY SECTOR (% OF COMPANIES COLLECTING ≥ 1 REGULATED DATA TYPE)

Sector	GDPR	CCPA	HIPAA
Healthcare (n=56)	45/56 (80%)	43/56 (77%)	40/56 (71%)
IT (n=66)	58/66 (88%)	54/66 (82%)	51/66 (77%)
Financial (n=62)	55/62 (89%)	54/62 (87%)	50/62 (81%)

GDPR and CCPA exposure is consistently high across all sectors, ranging from 77% to 89%, which is expected given that email address and IP address alone trigger both frameworks. The right panel of Figure 6 contextualizes this: CCPA encompasses the largest regulated data type vocabulary (approximately 68 types), with the majority shared across all three sectors (dark grey), explaining its broad exposure. GDPR, though narrower in vocabulary (approximately 32 types), achieves similarly high exposure because its terms, including IP addresses, cookies, and biometric data, are near-universally collected. HIPAA’s vocabulary (approximately 36 types) produces the most sector-differentiated exposure pattern.

The more consequential finding is HIPAA exposure outside Healthcare. Financial Services leads all sectors with 81% HIPAA exposure, driven by insurance subsidiaries and health plan operations embedded within S&P-500 financial conglomerates. IT sector HIPAA exposure reaches 77%, exceeding Healthcare’s 71%, and reflects health technology platforms, HR software processing employee medical records, and wellness application providers. These companies may not recognize their HIPAA obligations based on primary sector classification alone.

Beyond exposure, the analysis identifies compliance violations defined as instances where a regulated data type appears as a leaf node in the knowledge graph with no subsumption children, indicating that a privacy policy discloses a sensitive data category without specifying the underlying sub-types collected. Table IV presents the most prevalent regulated violation types across sectors.

Three data types, namely *person name*, *IP address*, and *postal address*, appear as vague leaf-node disclosures under all three regulatory frameworks simultaneously, representing the highest-risk violation pattern in the corpus. These appear across all sectors with high company counts, confirming that even the most fundamental identifiers are frequently disclosed without sub-type specificity.

Sector-specific violation patterns diverge in the sensitive tier. The IT sector records the highest violation count for *cookie/pixel tag* (43 companies, GDPR), consistent with its tracking-intensive business model. The Financial sector exhibits the most concentrated violations around identity and financial identifiers: 21 companies disclose *SSN* as an unspecified leaf node, 16 disclose *date of birth*, and 11 disclose *driver’s license number*, a term entirely absent from IT company disclosures, all falling under CCPA and HIPAA simultaneously. The Financial sector also records 13 companies disclosing *biometric information* without sub-type detail, exceeding both IT (3) and Healthcare (6), an unexpected pattern suggesting that financial institutions collecting biometric authentication data are not fully articulating its scope in their privacy policies. Healthcare, despite being the sector most associated with HIPAA, produces the lowest violation counts across identity and financial identifiers, suggesting greater disclosure specificity in health-regulated data categories.

Network-level metrics reinforce these findings. There are 1,142 distinct paths from the “we” collector node to the GDPR regulation node at path-length cutoff 4, with *cookie/pixel tag* serving as the primary entry point. CCPA is the most structurally influential regulation in the graph (PageRank 0.009), consistent with its broader vocabulary and the large cross-sector shared component visible in Figure ???. The Financial sector generates the highest violation signal density (156 edges), consistent with its greater use of explicit financial identifier language and the thick outbound edges visible from the Financial anchor in Figure 5.

D. Graph Algorithm Results

The graph traversal results collectively address a limitation of exposure percentage alone: knowing that 88% of IT companies collect GDPR-regulated data does not reveal whether that collection is specific, direct, or structurally pervasive. The four algorithms together answer those structural questions.

BFS from “personal information” at depth 2 reveals that this single category node has a large number of Category and DataPoint descendants reachable within two hops in the unified knowledge graph, confirming that it functions as a universal umbrella term across all three sectors rather than a precise disclosure category. This is significant because a company that discloses “personal information” as a top-level node without specifying sub-types is technically acknowledging collection while providing no actionable detail about what is actually gathered. Under GDPR Article 13 and CCPA Section 1798.100, disclosures must identify the specific categories of personal information collected, meaning that bare umbrella disclosures of this kind constitute a violation candidate regardless of sector. The BFS result therefore provides structural evidence for why vague catch-all language is not merely an aesthetic problem but a measurable compliance gap.

DFS from “health information” reveals a structural divergence between sectors that has direct HIPAA implications. Healthcare sector company graphs consistently produce longer DFS chains with multiple SUBSUM levels, for example “health information” $\supset$ “medical history” $\supset$ “diagnosis”, indicating that these companies enumerate PHI sub-types in meaningful detail. By contrast, IT and Financial company graphs predominantly show “health information” as a bare leaf node with no sub-type specification. This distinction matters because HIPAA’s Safe Harbor method requires the explicit identification of the 18 enumerated identifiers; a policy that mentions health information without enumerating which identifiers are collected does not satisfy this requirement. The DFS result therefore provides a graph-structural mechanism for identifying HIPAA violation candidates that cannot be detected through vocabulary matching alone, since the regulated term is present but the required specificity is absent.

Shortest path analysis between company nodes and data type nodes confirms that the majority of direct collection relationships are 2-hop paths of the form Company $\rightarrow$ Entity $\rightarrow$ DataPoint, representing first-party collection. Paths of 3 or 4 hops indicate collection routed through third parties, a structurally distinct pattern with separate regulatory implications under GDPR Article 28, which imposes additional obligations on controllers who share data with processors. The ability to distinguish direct from indirect collection pathways within the graph therefore surfaces compliance obligations that a flat vocabulary match would miss entirely.

All-paths analysis from the “we” entity node to the GDPR regulation node identifies 1,142 distinct disclosure routes connecting the primary collector to GDPR-regulated data types at a path cutoff of 4. This figure is significant not as a count of violations but as a measure of structural exposure

TABLE IV
TOP REGULATED VIOLATION TYPES BY SECTOR (COMPANY COUNT)

Data Type	Regulations	Healthcare	IT	Financial
cookie / pixel tag	GDPR	29	43	36
person name	GDPR+CCPA+HIPAA	33	38	30
email address	CCPA+HIPAA	30	35	33
ip address	GDPR+CCPA+HIPAA	26	34	24
phone number	CCPA+HIPAA	24	30	25
postal address	GDPR+CCPA+HIPAA	21	24	26
SSN	CCPA+HIPAA	8	2	21
date of birth	CCPA+HIPAA	8	3	16
driver's license number	CCPA+HIPAA	2	0	11
biometric information	GDPR+CCPA+HIPAA	6	3	13

breadth: a higher path count means that GDPR-regulated data is reachable through more diverse routes in the graph, making it harder for a company to claim that regulated data collection is incidental or limited. Taken together with the exposure percentages in Table III, the path count confirms that GDPR scope is not only wide in terms of company count but also deep in terms of the variety of pathways through which regulated data enters the collection graph.

E. Centrality Analysis

The centrality analysis produces four charts. Top Data-Points by In-Degree shows that a small set of data types—*personal information*, *email address*, *IP address*, *cookies*, and *phone number* have dramatically higher in-degree than all others, confirming the universal baseline finding from a graph-structural perspective. Each of these top-5 nodes carries multiple regulation tags (GDPR, CCPA, and/or HIPAA), making them simultaneously the most collected and the most regulated data types in the corpus.

Top Categories by In-Degree shows “personal information” as the dominant umbrella, with an in-degree of 386 - far exceeding any other category. The gap between “personal information” and the next most common category confirms that this vague term is the primary vehicle through which companies avoid specific disclosure.

Top Entities by PageRank is dominated by self-referential actors (“we”, “the company”, “our organization”), confirming that companies are their own primary data collectors across all sectors. Third-party entities with notable PageRank include analytics providers and advertising platforms, with social media platforms particularly prominent in Healthcare (36% of companies) and service providers dominant in both IT (26%) and Financial (40%).

Regulated Data Points per Framework reveals that CCPA has the broadest coverage (PageRank 0.009, broadest vocabulary match in corpus), followed by GDPR and HIPAA. Despite HIPAA having fewer unique regulated types, its 183 edges indicate that PHI identifiers are being collected repeatedly across many companies, including those outside Healthcare, where 77% of IT and 81% of Financial companies are in scope. The most-collected GDPR type is *cookie/pixel tag* (IT: 65%, Financial: 58%, Healthcare: 52%); the most-collected

type under all three frameworks simultaneously is *person name* (Healthcare: 59%, IT: 58%, Financial: 48%).

F. Node-Focus Ego-Graph: Personal Information

The node-focus ego-graph centers on “personal information” as shown in Fig. 7 displays every data type directly linked to it as a category or sub-type across the corpus. Node color encodes the dominant sector (Healthcare in red, IT in teal, Financial in yellow, shared equally in purple), node size encodes total company count, and a red ring marks regulated nodes. The visualization reveals that the data types immediately surrounding “personal information” span all three sectors—they are universally collected regardless of industry. Regulated nodes (red rings) are densely distributed throughout the ego-graph, confirming that the vast majority of data types collected under the “personal information” umbrella are subject to at least one of GDPR, CCPA, or HIPAA.

VI. CONCLUSION AND FUTURE WORK

Our framework produces four principal findings. First, a universal baseline of digital identifiers, including email address, IP address, cookies, and phone number, is collected by virtually every company across all three sectors, bringing 77-89% of the corpus into GDPR and CCPA scope regardless of industry. This confirms that baseline digital compliance obligations are universal and cannot be treated as sector-specific concerns. Further, the absence or presence of privacy regulation keywords in a privacy policy can indicate a potential risk indicator for digital privacy compliance violations. Second, sectors diverge at the regulated-data tier: Healthcare uniquely collects PHI sub-types under HIPAA; IT uniquely collects behavioral and device identifiers under GDPR and CCPA; and Financial uniquely collects financial and government identifiers under CCPA. This divergence demonstrates that no single regulatory framework is sufficient for any sector, and that users face fundamentally different privacy risks depending on which industry they interact with. This information could inform and support the development of comprehensive privacy regulations in nations that have not adopted a global privacy protection regulation, like the United States. Third, HIPAA regulatory exposure extends well beyond Healthcare: 81% of Financial companies and 77% of IT companies collect data matching HIPAA’s 18 Safe Harbor identifiers, revealing

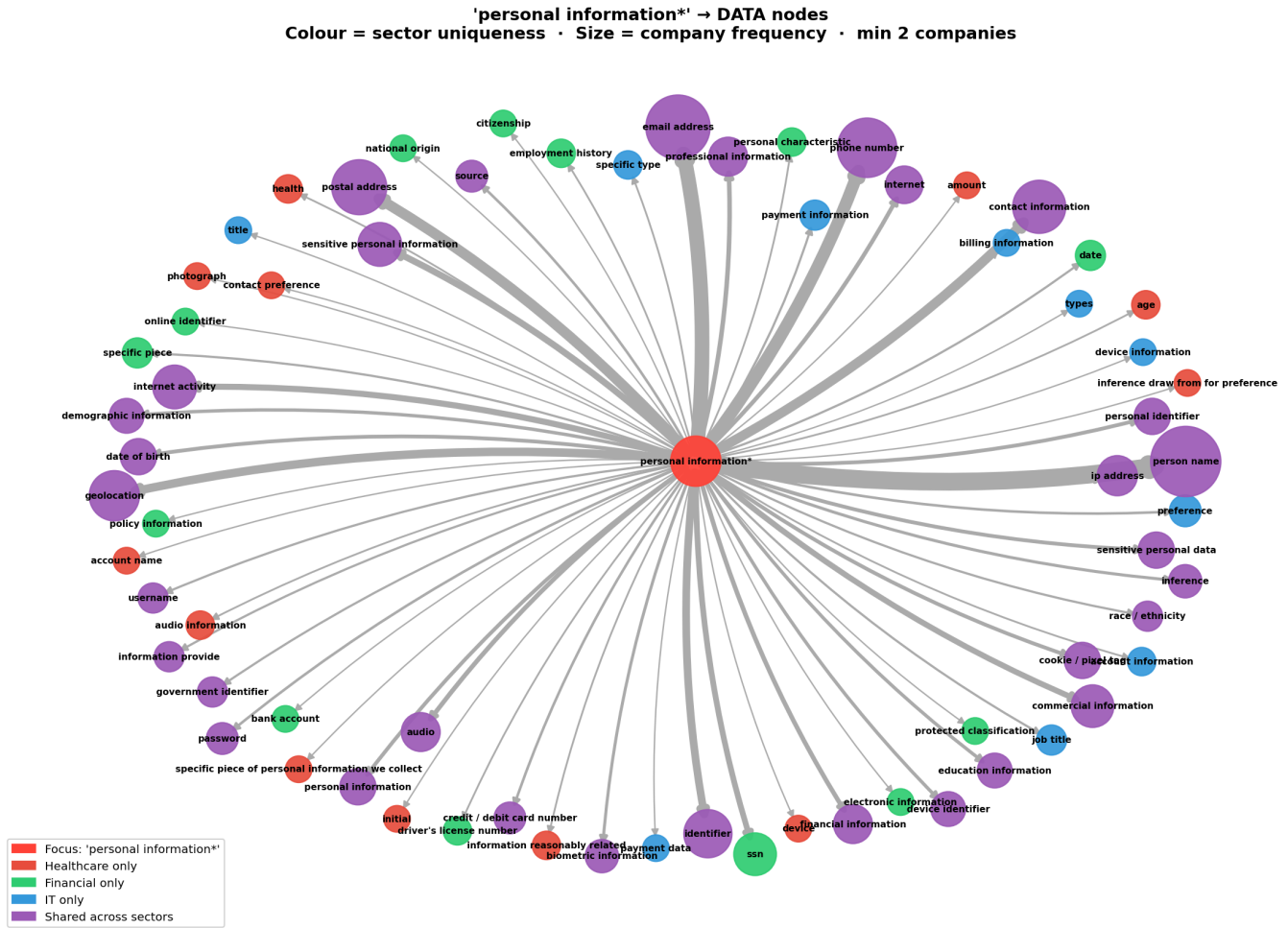


Fig. 7. Improved Privacy Policy Knowledge Graph - IBM

compliance obligations that sector classification alone does not predict and that users would not anticipate from industry label alone. Fourth, vague leaf-node disclosures are systematic across all sectors, with regulated data types such as "health information" frequently appearing as bare nodes without subtype specificity. This constitutes disclosure without actionable detail, and our framework makes this obfuscation detectable at scale, providing regulators with a mechanism to identify non-compliant disclosures without manual policy review.

Current research leaves critical questions unanswered. Existing tools assess individual policies [2], [5], [6] but cannot compare compliance across sectors or identify sector-specific patterns at scale, and prior studies are limited to 55-100 policies from single domains [5], [6]. Our framework addresses these gaps by building knowledge graphs from policies across all three sectors and applies graph traversal, centrality analysis, and regulatory vocabulary matching to reveal sector-specific patterns and translate technical graph structure into practical compliance signals. The practical contribution is threefold: users can identify which companies collect data beyond their sector baseline; regulators can detect vague disclosure patterns

at scale without manual review; and compliance teams can locate the specific nodes in their policy graph that represent the greatest regulatory exposure. Future work will apply clustering techniques to identify compliance archetypes across industries and train predictive models on GDPR, HIPAA, and CCPA regulatory frameworks to automatically flag policy deviations and potential violations.

REFERENCES

- [1] J. Yerby and I. Vaughn, "Deliberately confusing language in terms of service and privacy policy agreements," *Issues in information systems*, vol. 23, no. 2, pp. 138–149, 2022.
- [2] H. Cui, R. Trimananda, A. Markopoulou, and S. Jordan, "PoliGraph: Automated privacy policy analysis using knowledge graphs," in *32nd USENIX Security Symposium (USENIX Security 23)*, (Anaheim, CA), pp. 1037–1054, USENIX Association, Aug. 2023.
- [3] L. Garza, L. Elluri, A. Piplai, A. Kotal, D. Gupta, and A. Joshi, "Privcomp-kg: Leveraging kg and llm for compliance verification," in *2024 IEEE 6th International Conference on Trust, Privacy and Security in Intelligent Systems, and Applications (TPS-ISA)*, pp. 97–106, 2024.
- [4] K. P. Joshi, L. Elluri, and A. Nagar, "An integrated knowledge graph to automate cloud data compliance," *IEEE Access*, vol. 8, pp. 148541–148555, 2020.
- [5] V. Ramasamy, S. Barrett, G. Dorai, and J. Zumbach, "Unveiling privacy policy complexity: An exploratory study using graph mining, machine learning, and natural language processing," in *2025 6th International*

Conference on Artificial Intelligence, Robotics and Control (AIRC), pp. 514–520, 2025.

- [6] S. Barrett, V. Ramasamy, G. Dorai, and B. Boswell, “Navigating privacy policies with nlp and graph mining: Advancements in user-centric legal document analysis,” in *SoutheastCon 2025*, pp. 1013–1022, 2025.
- [7] R. N. Zaeem and K. S. Barber, “The effect of the gdpr on privacy policies: Recent progress and future promise,” *ACM Trans. Manage. Inf. Syst.*, vol. 12, Dec. 2020.
- [8] U. D. of Health and H. Services, “Health information privacy,” in *HHS.gov*, 2024.
- [9] S. of California; Department of Justice, “California consumer privacy act,” in *oag.ca.gov*, 2024.
- [10] E. Parliament and the Council, “General data protection regulation (gdpr) – legal text.”
- [11] C. Barrett, “Are the eu gdpr and the california ccpa becoming the de facto global standards for data privacy and protection?,” *Scitech Lawyer*, vol. 15, no. 3, pp. 24–29, 2019.
- [12] V. Belcheva, T. Ermakova, and B. Fabian, “Understanding website privacy policies—a longitudinal analysis using natural language processing,” *Information*, vol. 14, no. 11, 2023.
- [13] H. Chowdhury, M. I. Morsalin, R. S. Azade, and V. Ramasamy, “Graphdpr: A privacy policy analysis framework using knowledge graphs and topic modeling,” in *Social Networks Analysis and Mining - 17th International Conference, ASONAM 2025, Proceedings*, vol. 16322, pp. pp. 422–430, 2026.
- [14] Z. Munn, J. Peters, Micah D. C. Stern, C. Tufanaru, A. McArthur, and E. Aromataris, “Systematic review or scoping review? guidance for authors when choosing between a systematic or scoping review approach,” *BMC Medical Research Methodology*, vol. 18, no. 1, p. 143, 2018.
- [15] . G. U. Bahr, C., “Gdpr vs ccpa compliance: Key differences explained.”
- [16] DCHS, “Dhcs: list of hipaa identifiers.”

APPENDIX

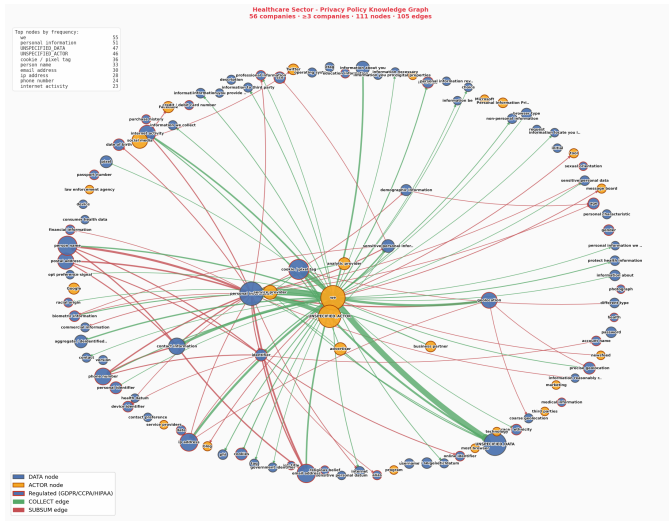


Fig. 8. Healthcare Sector Knowledge Graph

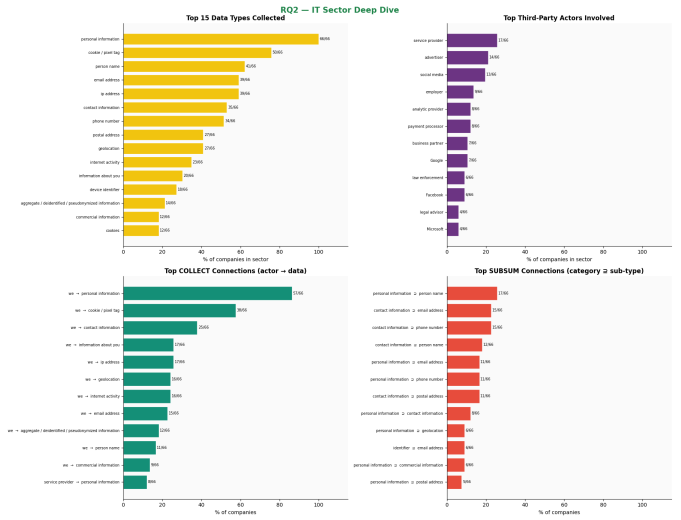


Fig. 9. IT Sector Knowledge Graph

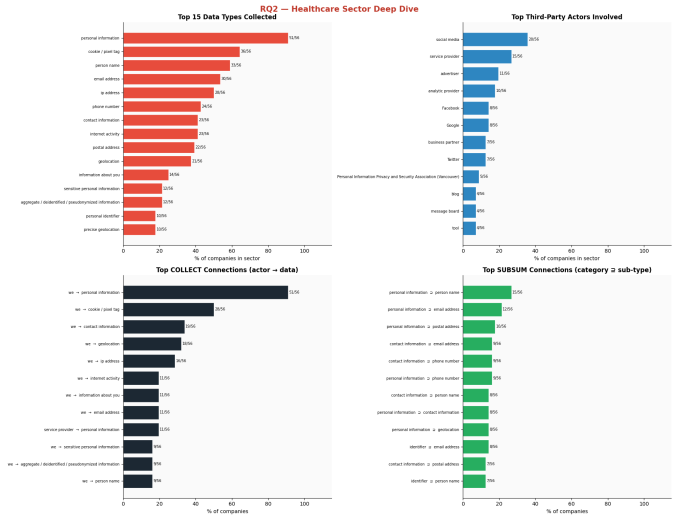


Fig. 10. Healthcare Sector Deep Dive

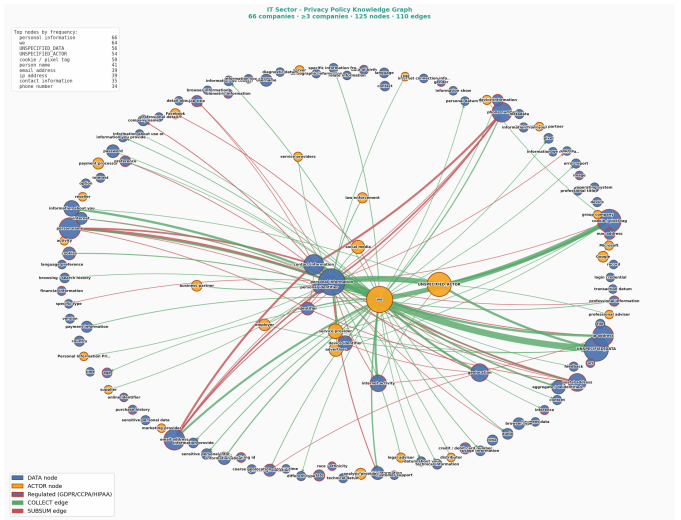


Fig. 11. IT Sector Deep Dive

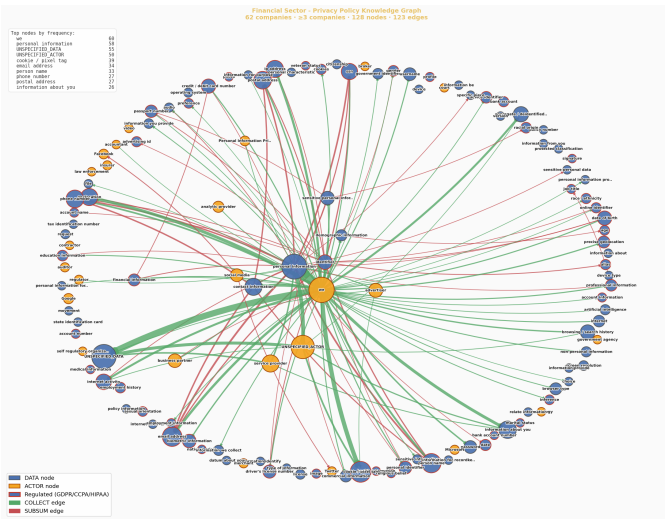


Fig. 12. Financial Sector Knowledge Graph

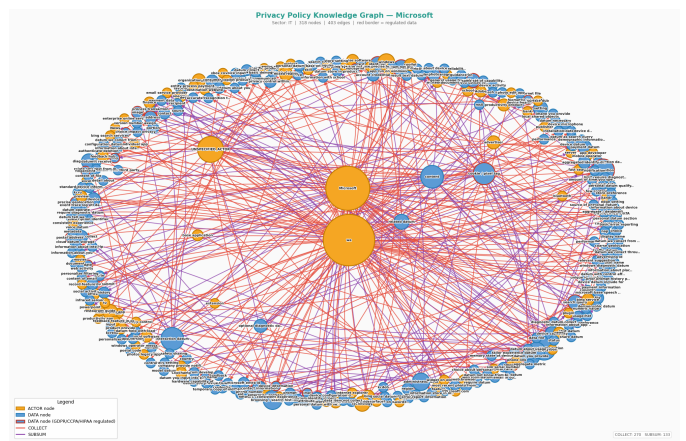


Fig. 15. Microsoft Knowledge Graph

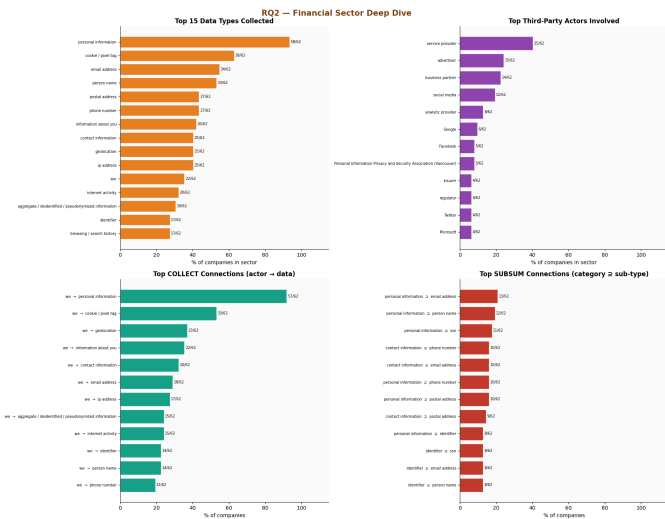


Fig. 13. Financial Sector Deep Dive

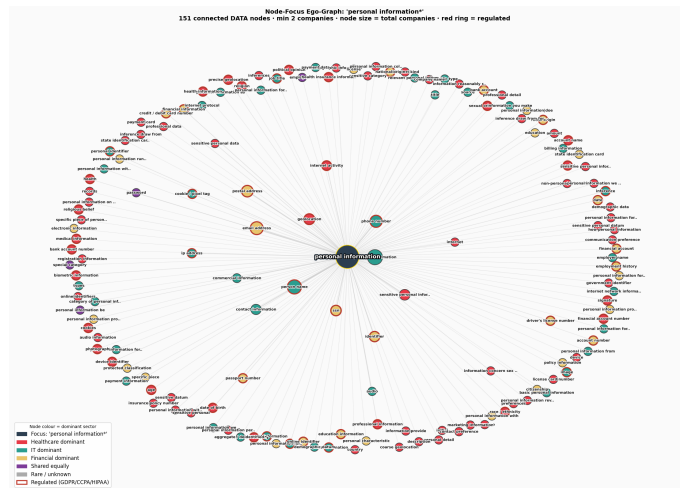


Fig. 16. Node Focus Eco Graph

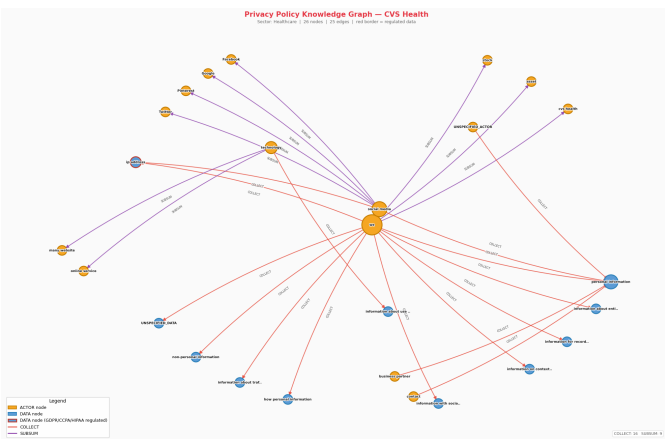


Fig. 14. CVS Health Knowledge Graph

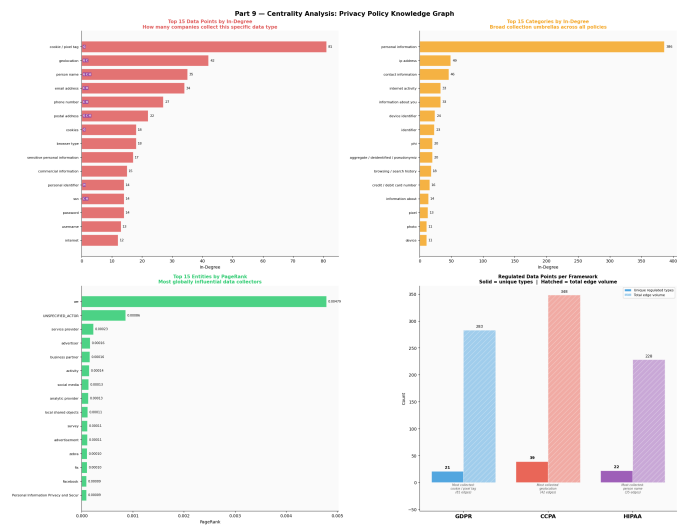


Fig. 17. Node Focus Eco Graph